AI-CAL

AI Containment Assurance Levels

Framework and reference architecture



Author: Patrick Shannon
CISSP, CISA, CRISC, GISP, GPEN, GCLD, CDPSE, GPPA, Security+
Principal Security Architect Consultant
LinkedIn: https://www.linkedin.com/in/patrick-shannon-cissp-crisc-cisa-gisp-gpen-gcld-cdpse-b7726b2/
Credly: https://www.credly.com/users/patrick-shannon.d59e52e2/badges/credly

© 2026 Patrick Shannon. Licensed under Creative Commons Attribution 4.0 International (CC BY 4.0).

Patrick Shannon
Digitally signed by Patrick Shannon
Date: 2026.11.07 10:56:16 -05'00'

Agent Containment Strength & Assurance Levels Chart

Bridging hazard-driven requirements, containment architecture, and measurable assurance

HAZARD / BUSINESS NEED
Why containment is needed

AI-CAL
A common model from risk to implementation

IMPLEMENTATION & EVIDENCE
How assurance is demonstrated

Build the architecture, apply controls, and provide evidence of containment strength.

Hazard ➡ Required Strength
TOP-DOWN
Five assessment inputs

- **Capability** — What can it execute or change?
- **Autonomy** — What can it initiate without approval?
- **Connectivity** — Which services must the task reach?
- **Consequence** — How severe could the impact be?
- **Concurrency** — How many agents run at the same time?

ASSESS TOGETHER
Required AI-CAL profile
and supporting capacity

Agent Behavior Deterrence & Enforcement

AI-CAL 0	**Unassured / Uncontained**	Broad user-equivalent authority; no defined boundaries
AI-CAL 1	**Basic Isolation**	Sandbox; material shared dependencies remain
AI-CAL 2	**Development Containment**	Dedicated environment; distinct identity and bounded tools/network
AI-CAL 3	**Strong Virtual Containment**	Dedicated VM/cell; micro-zoning and brokered access
AI-CAL 4	**High-Assurance Hybrid**	Separate zones and bounded conduits; stateful enforcement
AI-CAL 4.5	**Enhanced Hybrid**	Separate hostile/trusted host pools; physical enforcement and independent one-way paths
AI-CAL 5	**Physical Containment**	Independent physical controls; reduced reliance on shared virtualization
AI-CAL 6	**Air-Gapped / Sovereign**	No live external operational dependency; inference and support services inside boundary

BOTTOM-UP
Evidence ➡ Assurance Claim

- Architecture review
- Boundary testing
- Config baselines
- Negative-path tests
- Operational telemetry
- Exceptions & owner

A control's presence is not enough. AI-CAL evaluates the strength and independence of containment enforcement.

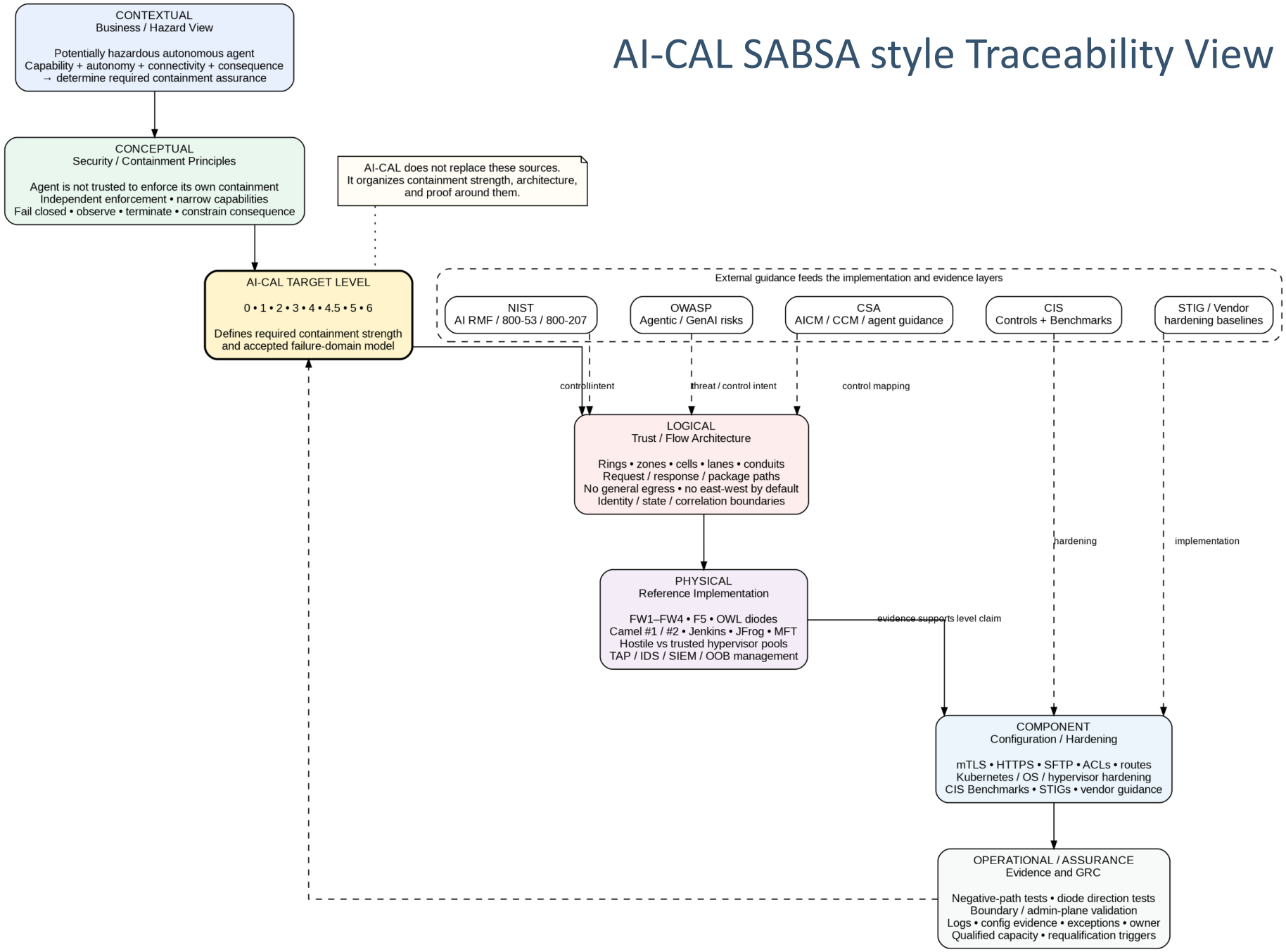
Example Supporting Sources

NIST · OWASP · CSA · CIS Controls · CIS Benchmarks · STIGs · Vendor Guidance

External frameworks provide control objectives and implementation guidance.
AI-CAL determines the required containment strength and evidence.

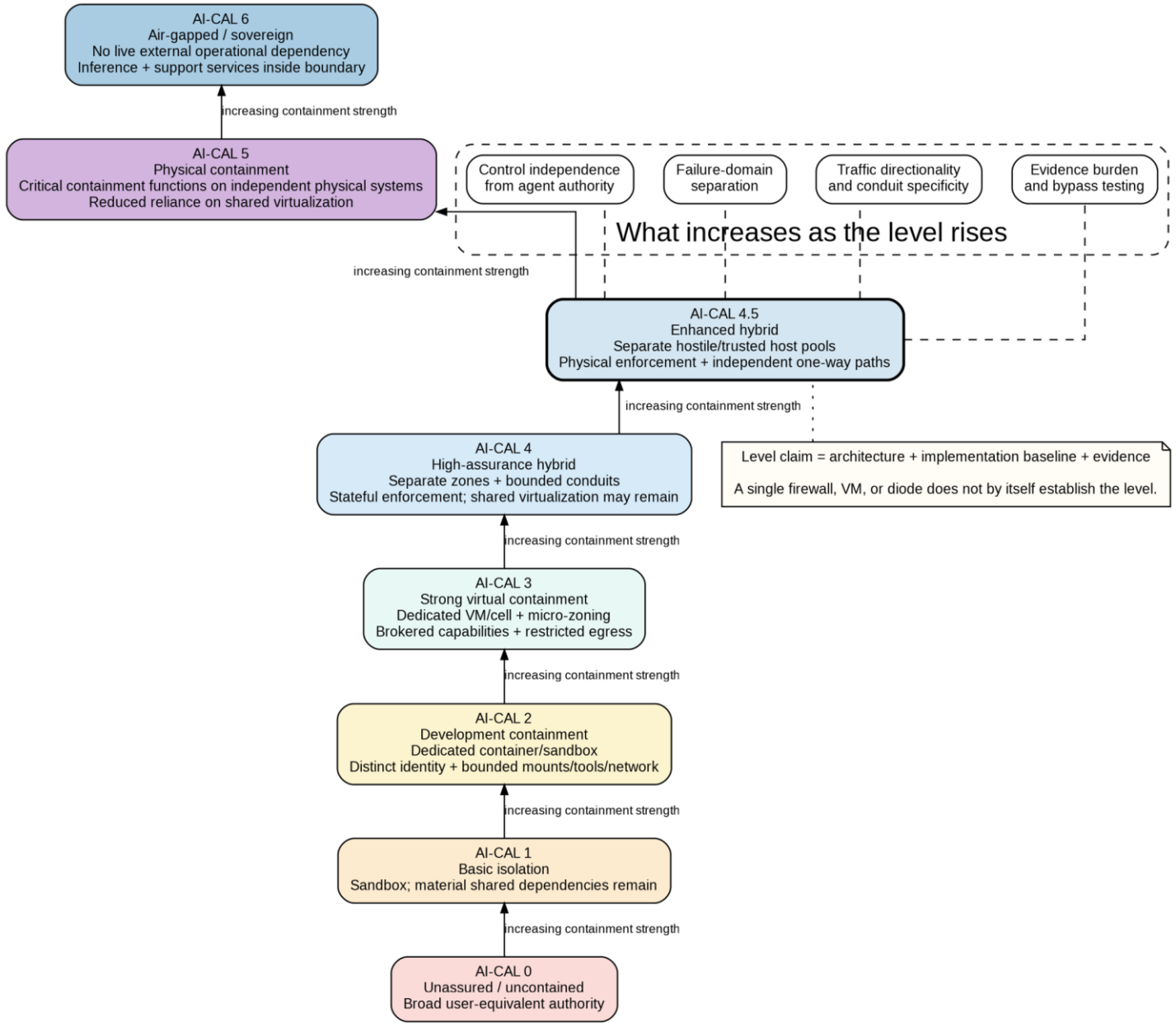
© 2026 Patrick Shannon | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

AI-CAL SABSA style Traceability View



© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

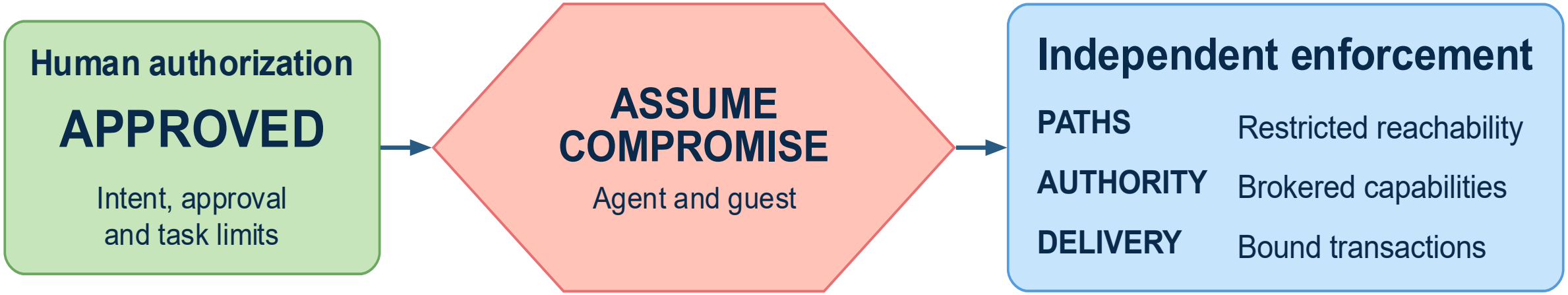
AI-CAL Containment Strength & Assurance Progression Chart



© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

Human approval needs enforceable boundaries

AI-CAL asks what still contains the agent after compromise.



Reachability	Which systems and services can a compromised agent reach?
Failure propagation	What capability remains after one control is bypassed?
Operator intervention	Can independent controls inhibit access and stop the workload?

© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

The use case sets the required profile

Scored indicators propose a target. Mandatory floors and holds constrain the decision.

Five assessment inputs

01 Capability
Code, privileges, tools and credentials

02 Autonomy
Duration, delegation and freedom to act

03 Connectivity
Work assets, providers and trust boundaries

04 Concurrency
Fleet size, coupling and shared services

05 Consequence
Data class, business impact and recovery

Proposed containment profiles

- **0** Unassured / uncontained
- **1** Basic isolation
- **2** Development containment
- **3** Strong virtual containment
- **4** High-assurance hybrid
- **4.5** **Enhanced hybrid with physical separation**
- **5** Physical containment
- **6** Air-gapped / sovereign operation

Selection records required containment. Evidence establishes achieved assurance.

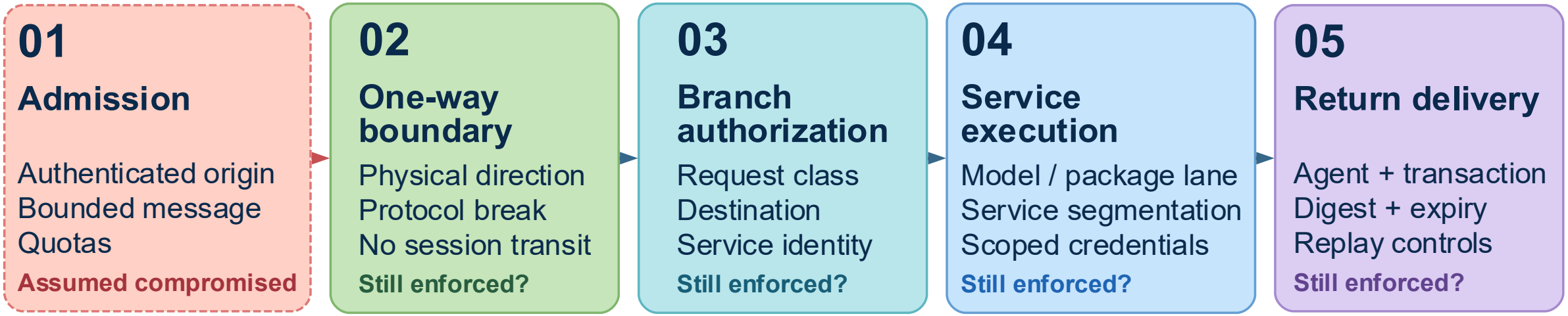
© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

Each tollgate limits the next capability

Component count helps when authority, failure domains and recovery paths are independent.

Example: assume admission is compromised

Schematic enforcement functions



Failure test | **Compromise one control. Trace every remaining route, credential and administrative dependency.**

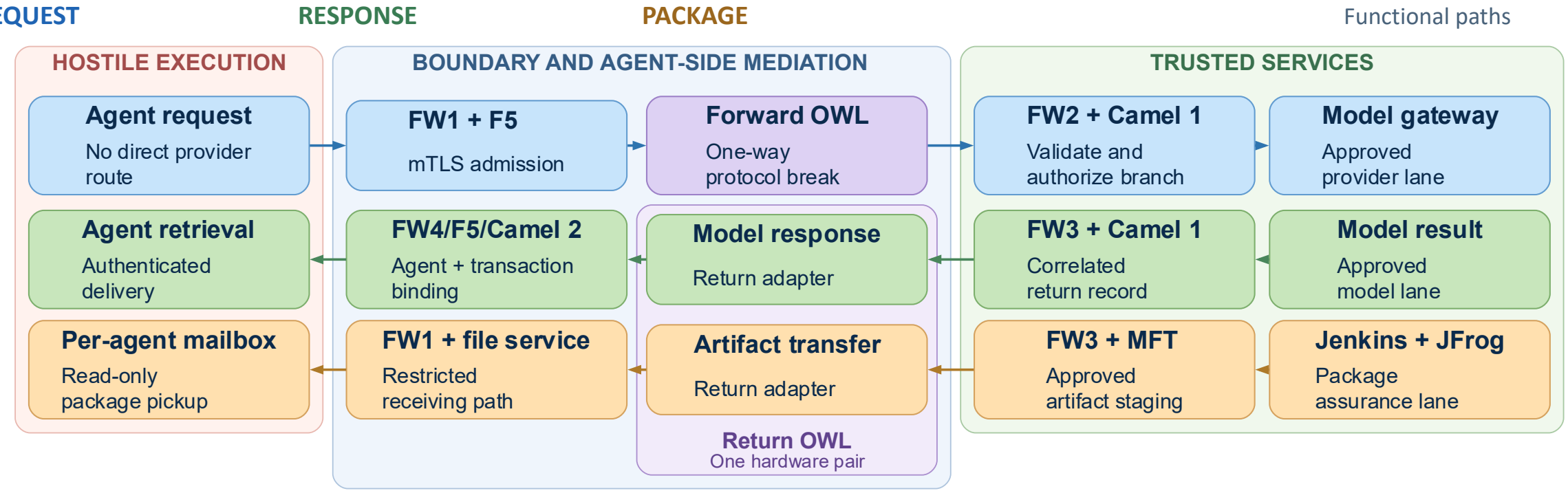
A bypass must not automatically grant the next authority.

Shared management can defeat apparent independence.

© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

AI-CAL 4.5 bounds three distinct paths

Hostile compute and trusted processing occupy separate physical host pools.



Independent management, telemetry and cutoffs remain outside agent control.

Camel 1 branches package requests to Jenkins/JFrog/MFT.

Response and artifact adapters share one return diode pair, independent of the forward path.

© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

One target can lead to different decisions

Illustrative outputs from the draft assessment. Deployment evidence remains necessary.

Scenario	Decisive condition	Target	Deployment implication
Bounded developer agent	Restricted tools, network and data	**3**	Dedicated cell and brokered access need supporting evidence.
Hostile guest-root research	Assume the guest is compromised	**4.5**	Physical separation and one-way boundaries need failure-path testing.
1,000-agent coordinated fleet	Scale, coupling and shared dependencies	**4.5**	**HOLD** until monitoring, queues and coordinated cutoff are qualified for this load.
Sovereign local research	No live external dependency allowed	**6**	A hosted model **conflicts** with the selected operating constraint.

Selection sets the target. Evidence determines deployment readiness.

Synthetic calibration cases from AI-CAL containment assessment spreadsheet. Proposed targets do not establish achieved assurance.

© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

An AI-CAL claim carries evidence and limits

A claimed level applies to the paths, identities, failure modes and load actually demonstrated.

Minimum evidence bundle

01 Architecture and authority
Topology, identities, credentials and management dependencies

02 Negative paths and failures
Bypass, wrong-agent, replay, expiry, outage and failover tests

03 Qualified operating capacity
Concurrent cells, throughput, queue limits and cutoff time

Scoped claim template

Profile [level] / Scope [cell or pod]

Qualified capacity: [demonstrated load]

Control envelope: [capability, autonomy, connectivity and duration]

Evidence: [test record and configuration]

Exceptions: [owner, limits and expiry]

SABSA / TOGAF fit

Business need → Containment requirements → Architecture → Evidence

Proposed mapping. Reference design and scoring remain subject to integrated qualification.

© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

Containment needs independent visibility

Proposed workflow: monitor boundaries, correlate behavior and turn confirmed crossings into tests.

01
Observe
Network TAPs + IDS
FW / F5 / broker logs
Host / admin events

02
Correlate
SIEM: agent + transaction
Zone + boundary + time
Sensor / queue health

03
Respond
Verify scope and reach
Independent cutoffs
Preserve trusted evidence

04
Learn
Root cause + shared paths
Repair controls and rules
Retest before recovery

Behavior to investigate	Forbidden egress, replay, identity mismatch, tool misuse and rate or queue abuse.
After a zone breach	Trace the first crossing. Identify which next tollgate held or failed. Repair the cause and replay the case before requalification.

Keep collection, cutoff authority and recovery approval outside agent control.

For TLS, combine TAP/IDS flow metadata with approved endpoint events.
Qualify sensor coverage, alert delay, log loss and cutoff completion at load.

© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0

Control authority sets an assurance ceiling

Proposed for the next revision: assess control across OSI Layers 1-7 and supporting platforms.

01

Scope the controls

OSI L1-L7 paths
Firmware and host platforms
Management and recovery
Shared control dependencies

02

Establish authority

Change, bypass and restore
Cutoff / isolation authority
Provider and administrator roles
Configuration + test evidence

03

Qualify the claim

Mandatory controls satisfied
Inherited controls assessed
Trust dependencies explicit
Unmet requirement: hold

Illustrative 4.5 decision

Required target: 4.5 → Physical boundary or cutoff authority not demonstrated → **Achieved: not established** **Deployment: HOLD**

Required protection stays fixed. Evidence limits the eligible assurance claim.

Assess inherited controls against the profile. Required exclusive authority must be demonstrated.

© October 2026 Patrick Shannon | AI Containment Assurance Levels (AI-CAL) supporting deck v1.0 | Visual summary | Level qualification requires the complete profile and evidence | CC BY 4.0